

*Security Fundamentals · Section 9*

# *Ethics, the Law, and Permission to Test*

*By TOUCH DEN · November 11, 2026*

# Contents


What You Will Learn 1

Before You Start 1

1. Why Ethics Comes First 1

2. The One Rule, Restated 1

3. Authorization, Scope, and Rules of Engagement 2

4. Bug Bounties and Responsible Disclosure 3

5. The Shape of Computer-Crime Law 3

6. Data Protection and Privacy Duties 4

7. Professional Ethics and What to Do If You Find Something 4

Common Mistakes 5

Summary 6

Check Your Understanding 6

Practice 7

## What You Will Learn

- Why the ethics rule matters more than any technique.
- The one rule, restated and made precise.
- What proper authorization looks like: scope and rules of engagement.
- Bug bounties and responsible disclosure: the legal way to help.
- The shape of computer-crime law, and how to find your own country's.
- Your duties around personal data and privacy.
- Professional ethics, and what to do if you find a vulnerability.

## Before You Start

Read lessons 1 to 8. You now understand attacks and defenses well enough that the question "what am I allowed to do with this knowledge?" is urgent. This lesson answers it.

**A note on the law:** this lesson teaches the shape of the rules, not legal advice. Laws differ by country and change over time. Where your actions might have legal consequences, confirm the current law in your own country, or ask a qualified lawyer. The specifics here are illustrative.

---

## 1. Why Ethics Comes First

By now you could describe how phishing works, how passwords are cracked, how attacks move through a network. That knowledge is exactly what a defender needs, and exactly what a criminal uses. The only thing that separates the two is **permission and intent**. That is why ethics is not a soft add-on to security; it is the line that decides whether you are a professional or a criminal, and the skills on both sides are identical.

This matters practically, not just morally. A security career is built on **trust**. Employers, clients, and the public hand security people deep access and powerful tools. One serious ethical breach, testing without permission, peeking at data you were not authorized to see, ends that trust and often a career, regardless of how skilled you are. In this field, your reputation for integrity is worth as much as your technical ability.

## 2. The One Rule, Restated

Here is the rule from lesson 1, now stated precisely:

> ***Only ever access or test a system when you own it, or you have clear, specific, written permission from someone with the authority to grant it.***

*Every word earns its place:*

- ***Own it, or have permission:*** *your own lab and your own accounts are always fine. Anything else needs permission.*
- ***Clear and specific:*** *"you can test our stuff" is not enough. Permission must say which systems, what you may do, and when.*
- ***Written:*** *verbal permission protects no one. If it is not in writing, it did not happen.*
- ***From someone with the authority:*** *a friend who works at a company cannot authorize you to test the company's systems. Only the owner, or someone the owner empowered, can.*

*And the rule's hard edges, repeated because they are where people go wrong:*

- *Curiosity is not permission.*
- *"It was easy / exposed / public" is not permission.*
- *"I didn't change anything, I only looked" is not permission, looking is access.*
- *"I wanted to help" is not permission, unless you were invited (topic 4).*

*There is no fifth exception. When in doubt, you do not have permission.*

## *3. Authorization, Scope, and Rules of Engagement*

*When security work is authorized, for example a professional penetration test, the permission is written down in detail before any testing begins. Two documents matter:*

- ***Scope*** *defines exactly what may be tested: which systems, addresses, applications, and accounts are* ***in scope****, and, just as importantly, what is* ***out of scope*** *and must not be touched. Testing something out of scope, even by accident, can be illegal and is always a serious breach.*
- ***Rules of engagement (RoE)*** *define how the test runs: the time window (often outside business hours), which techniques are allowed (for example, "no denial-of-service", "no social engineering of staff"), who to contact in an emergency, and how to handle any real data found.*

*Underpinning both is a signed* ***authorization****, sometimes called a "get out of jail free" letter, from someone with authority, stating that the tester is permitted to do this work. A professional never starts without it. These documents protect everyone: the client knows what will happen, and the tester has clear, provable permission. You will use real scope and RoE documents in the penetration testing courses.*

## 4. Bug Bounties and Responsible Disclosure

*What if you are not hired, but you genuinely want to help, or you stumble on a flaw? There are legitimate paths, and illegitimate ones.*

- ***Bug bounty programs** are standing invitations: a company publishes a policy saying "you may test these systems, within these rules, and we will reward valid findings". The published scope and rules are your written permission, as long as you stay strictly inside them. Platforms host these programs, and they are a popular, legal way to practise on real systems and earn money. The Careers course covers them.*
- ***Responsible (coordinated) disclosure** is the path when there is no bounty program and you have found a real flaw, usually in something you were legitimately using. You report it privately to the owner, give them reasonable time to fix it, and do not publish details or exploit it in the meantime. Done well, this helps everyone and keeps you on the right side of the line.*

*The crucial boundary: a bug bounty's published scope is permission; finding a flaw by chance is **not** permission to go digging further. The moment you start probing beyond what you were invited to do, or beyond what you encountered in normal use, you have crossed into unauthorized access.*

## 5. The Shape of Computer-Crime Law

*Almost every country has laws against unauthorized access to computer systems. The details vary, but the shape is consistent:*

- ***Unauthorized access** (getting into a system you are not permitted to) is an offense, often regardless of whether you caused any harm. Simply logging in without permission can be a crime.*
- ***Unauthorized modification** (changing data or systems) is treated more seriously.*
- ***Causing damage or loss**, or acting for financial gain, raises the penalties further.*
- ***Making or supplying attack tools** for criminal use can itself be an offense.*

*Well-known examples include the United States' Computer Fraud and Abuse Act and the United Kingdom's Computer Misuse Act; the European Union and most countries have equivalents. **Cambodia** has its own legal framework governing computer and online offenses, and it continues to develop. Because specifics and penalties change, **confirm the current Cambodian law before relying on any detail**, and treat the safe rule, no access without written permission, as your guide everywhere. Ignorance of the law is not a defense, and "I'm a student" or "I was learning" does not make unauthorized access legal.*

## 6. Data Protection and Privacy Duties

*Security people handle personal data constantly, logs, user records, the contents of a breach, and that carries legal and ethical duties. Personal data means information about identifiable people: names, phone numbers, addresses, health, finances, messages.*

*The widely shared principles (seen in the EU's GDPR and many national laws, including developing frameworks in Cambodia) include:*

- ***Collect only what you need,** and use it only for the stated purpose.*
- ***Protect it** with appropriate security (the whole point of this field).*
- ***Limit who can see it** (least privilege, lesson 7).*
- ***Keep it only as long as needed,** then delete it.*
- ***Respect people's rights** over their own data.*
- ***Report breaches** to authorities and affected people, often within a legal deadline.*

*For you as a learner and future professional, the practical duty is simple: when your work exposes you to real personal data, treat it with care, access only what you need, never copy or share it beyond the task, and never use it for curiosity or personal gain. Mishandling personal data can be both a crime and a firing offense.*

## 7. Professional Ethics and What to Do If You Find Something

*Beyond the law, the security profession holds itself to **codes of conduct**. Certifications and professional bodies ask members to act honestly, protect the public and their clients, work only within their competence and authorization, and disclose findings responsibly. The common thread is the one you already know: use your skills to protect, act only where permitted, and be honest.*

*Finally, a situation you will meet: **you find a vulnerability.** What do you do?*

1. ***Stop.** Do not probe further, and do not exploit it. Note what you already saw in normal use.*
2. ***Check for a path.** Does the owner have a bug bounty or a security contact (often a `security.txt` file or a "report a vulnerability" page)?*
3. ***Report privately** to the owner, with enough detail to reproduce it. Do not post it publicly.*
4. ***Give them reasonable time** to fix it before any disclosure, and keep records of your good-faith contact.*
5. ***Do not demand payment.** Asking for money to stay quiet looks like extortion, which is a crime, even if you meant well.*

*Report it the way you would want someone to report a flaw in your system: privately, helpfully, and without making things worse. That instinct, defend, don't exploit; help, don't harm; act only with permission, is the ethical core of everything that follows in this program. With it firmly in place, the next lessons look at the frameworks and roles that organize security work at scale.*

---

## Common Mistakes

***1. Treating ethics as optional.*** *Permission and intent are the only things separating a professional from a criminal; the skills are identical.*

***2. Relying on verbal or vague permission.*** *Permission must be written, specific about systems and actions, and from someone with authority. Otherwise you have none.*

***3. Thinking "I only looked" is safe.*** *Looking is access. Unauthorized access is often a crime regardless of harm.*

***4. Treating a found bug as a licence to dig.*** *Encountering a flaw in normal use is not permission to probe further. That step crosses into unauthorized access.*

***5. Assuming student status or good intentions protect you.*** *The law does not exempt learners or the well-meaning. Only your own systems or written permission do.*

***6. Mishandling personal data.*** *Access only what you need, never copy or share it, never use it for curiosity. It can be both a crime and a firing offense.*

***7. Asking for payment to stay quiet.*** *Demanding money over a vulnerability looks like extortion. Report responsibly; let any reward come through an official bounty.*

## Summary

| Idea | Remember |
|---|---|
| Why ethics first | Permission and intent are the only line between professional and criminal |
| The one rule | Access/test only what you own, or have clear, specific, written permission for |
| Scope & RoE | What may be tested, and how; signed authorization before any testing |
| Bug bounty | A published invitation = permission, within its rules |
| Responsible disclosure | Report flaws privately; give time to fix; don't exploit or publish |
| Computer-crime law | Unauthorized access is an offense, often regardless of harm; confirm local law |
| Personal data | Collect little, protect it, limit access, don't misuse it |
| If you find a bug | Stop, report privately, give time, don't demand payment |

## Check Your Understanding

1. What two things separate a security professional from a criminal, given identical skills?
2. State the one rule precisely, and explain why "written" and "from someone with authority" matter.
3. What is the difference between scope and rules of engagement?
4. How can testing a real company's systems ever be legal without being hired by them?
5. Is "I only looked, I didn't change anything" a legal defense? Why or why not?
6. Name three duties you have when handling personal data.
7. You find a serious flaw in a website you use. List the first three things you should do.

### Answers

1. Permission and intent. The technical knowledge is the same on both sides.
2. Only access or test a system you own, or have clear, specific, written permission for, from someone with authority. Written, because verbal permission protects no one and can't be proven; from someone with authority, because only the owner (or their delegate) can actually grant it.
3. Scope defines what may be tested (which systems are in or out of bounds); rules of engagement define how (timing, allowed techniques, contacts, handling of data).
4. Through a bug bounty program, whose published scope and rules are a standing written permission, as long as you stay strictly within them.

5. *No. Looking is access, and unauthorized access is often a crime regardless of whether you changed anything or caused harm.*
6. *Any three: collect only what's needed; use it only for its purpose; protect it; limit who can see it; keep it only as long as needed; respect people's rights; report breaches.*
7. *Stop and don't probe further or exploit it; check for a bug bounty or security contact; report it privately to the owner with enough detail to reproduce. (Then give time to fix, and never demand payment.)*

## Practice

1. *Rewrite the one rule in your own words, in a single sentence you could explain to a friend.*
2. *A friend says: "This local shop's website looks really insecure. Let me just try a few things to see if I can get in, I'd tell them afterwards so it's fine." Give two reasons this is not fine, and one legal way they could help instead.*
3. *Find out whether a website or app you use has a way to report security issues (look for a "security" page, a `security.txt`, or a vulnerability-disclosure policy). Write down what you found, or note that you could not find one.*

### A Worked Example

1. *"Don't touch any computer or account that isn't mine unless the owner has clearly, and in writing, said I can, and said exactly what I'm allowed to do."*
2. *Not fine because: trying to get in is unauthorized access, which is a crime even if nothing is changed and even if they'd tell the shop afterwards; and "I'd tell them after" is not the owner's permission in advance. A legal way to help: contact the shop privately, explain politely that they may have a security issue, and offer to help only if they ask, through responsible disclosure, not by breaking in first.*
3. *(Your findings. For example: "Checked a bank app's website; it has a 'Report a vulnerability' page with an email address and asks for private disclosure, that's a responsible-disclosure path.")*

---

*Course mark icon from Material Symbols by Google, Apache License 2.0. NIST, CIS, ISO, OWASP, and MITRE ATT&CK are the trademarks of their respective owners, used here only to refer to their published work.*